

Penetration Test Report

Home Lab Internal Network Assessment

Document control

Field	Value
Report title	Home Lab Internal Network Assessment — Penetration Test Report
Version	1.0
Classification	Confidential
Prepared by	<i>[Your name]</i> , DAE Cybersecurity Program
Prepared for	<i>[Instructor / lab owner]</i>
Engagement dates	<i>[start] – [end]</i>
Distribution	<i>[names]</i> — do not distribute beyond this list

Related working papers: R1 Engagement Plan · R2 Reconnaissance · R3 Vulnerability Assessment · R4 Network Testing · R5 Initial Exploitation. This report consolidates those phases into a single professional deliverable.

Table of Contents

1. Executive Summary
2. Scope & Objectives
3. Methodology
4. Summary of Findings
5. Detailed Findings
6. Remediation Roadmap
7. Conclusion
8. Appendix A — Evidence Index

9. Appendix B — Tools Used

10. Appendix C — Glossary (for non-technical readers)

1. Executive Summary

(Written for a non-technical reader — no commands or jargon.)

An authorized penetration test was conducted against the in-scope system `192.168.78.5` in a controlled lab environment to evaluate its security posture and identify weaknesses that a real attacker could exploit.

The assessment found that the system exposes a **remote administration service (Telnet) that transmits usernames and passwords with no encryption**. Any attacker with access to the local network could intercept administrator credentials and take complete control of the system. This was not just theoretical — during testing, credentials were successfully captured and used to gain access. This is a **High**-risk issue and should be corrected as a priority.

The test also confirmed that **weak passwords on exposed login services are easily recovered** with common tools, and that the **network lacks segmentation**, which increases the impact of any single compromise.

Overall risk rating: High. The single most important action is to disable Telnet and replace it with SSH, which encrypts all communication.

Findings at a glance:

Severity	Count
Critical	[0]
High	[2]
Medium	[1]
Low	[]

2. Scope & Objectives

Authorized scope: 192.168.78.5 on the isolated 192.168.78.0/24 lab network. All testing was covered by a signed authorization form (R1).

Explicitly out of scope: the VirtualBox host operating system, the home router, any other network device, and the public internet.

Objectives: identify vulnerabilities on the target, verify them, demonstrate their real-world impact within safe limits, and provide actionable remediation.

3. Methodology

The engagement followed the **Penetration Testing Execution Standard (PTES)**:

Phase	Activity	Working paper
Pre-engagement	Scope, authorization, rules of engagement	R1
Intelligence gathering	Passive OSINT + active enumeration	R2
Threat modeling	Prioritizing attack surface	R2
Vulnerability analysis	Automated scanning + manual verification	R3
Network/protocol testing	Enumeration, mapping, traffic analysis	R4
Exploitation	Controlled proof of concept	R5
Reporting	This document	R6

All activity was conducted on an isolated, snapshotted VM with safety controls in place and non-destructive techniques only.

4. Summary of Findings

ID	Finding	Severity	CVSS	Status
F-01	Cleartext credential transmission via Telnet	High	7.5	Confirmed & exploited
F-02	Weak password susceptibility on exposed login service	High	[]	Demonstrated (test account)
F-03	Lack of network segmentation	Medium	[]	Observed
[F-04]	[from your scans]	[]	[]	[]

5. Detailed Findings

Each finding follows the same structure so a technical reader can reproduce and fix it.

F-01 — Cleartext Credential Transmission via Telnet

Severity	High
CVSS 3.1	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Affected asset	192.168.78.5, port 23/tcp

Description: The host runs a Telnet service that transmits all data — including login credentials — without encryption. An attacker on the local network can intercept credentials in transit.

Evidence: *[Insert screenshot: Wireshark "Follow TCP Stream" showing the username and password in plaintext. Reference: [telnet-capture.pcap](#).]*

Steps to reproduce:

1. On the target, capture telnet traffic: `sudo tcpdump -i any -A 'tcp port 23' -w telnet-capture.pcap`
2. From the tester machine, connect: `telnet 192.168.78.5 23` and log in.
3. Open the capture in Wireshark; right-click a packet → **Follow** → **TCP Stream**.
4. Observe the credentials displayed as readable text.

Impact: Captured credentials belong to an account with administrative (`sudo`) rights, so interception leads to full compromise of the host.

Remediation: Disable Telnet and use SSH instead (see F-01 in Section 6).

F-02 — Weak Password Susceptibility on Exposed Login Service

Severity	High
CVSS 3.1	<i>[score/vector]</i>
Affected asset	192.168.78.5, login services

Description: Exposed login services accept weak passwords, which are recoverable with standard dictionary-attack tools. Demonstrated in a controlled manner against a dedicated test account.

Evidence: *[Insert screenshots: Hydra recovering the test-account password; John the Ripper --show output.]*

Steps to reproduce (controlled test account):

1. Create a weak test account and a small wordlist (per R5, Section 5.2).
2. Online attack: `hydra -l testuser -P wordlist.txt telnet://192.168.78.5 -t 4`
3. Offline attack: `sudo unshadow /etc/passwd /etc/shadow > hashes.txt` then `john --wordlist=wordlist.txt hashes.txt`
4. Observe the password recovered by both methods.

5. Clean up: `sudo userdel -r testuser`.

Impact: Weak credentials on any reachable login service allow account takeover without needing to intercept traffic.

Remediation: Enforce a strong password policy and account lockout (see Section 6).

F-03 — Lack of Network Segmentation

Severity	Medium
Affected asset	Lab segment <code>192.168.78.0/24</code>

Description: Hosts on the segment can freely communicate and observe each other's traffic, so a single foothold enables interception attacks like F-01.

Evidence: *[Insert: network map / Zenmap topology screenshot from R4.]*

Impact: Amplifies the impact of other findings — one compromised or malicious host on the segment can attack the rest.

Remediation: Segment the network and restrict which hosts can reach the target's management services (see Section 6).

6. Remediation Roadmap

Prioritized, actionable guidance. Address in priority order.

Priority	Finding	Action	Effort	Verification
1	F-01	Install SSH (<code>sudo apt install openssh-server</code>), confirm login on port 22,	Low	Re-scan: port 23 <code>closed</code> ; capture SSH traffic and confirm it is unreadable

Priority	Finding	Action	Effort	Verification
		then disable Telnet (<code>sudo update-inetd --disable telnet</code>) and remove it (<code>sudo apt remove inetutils-telnetd</code>)		
2	F-02	Enforce strong passwords; enable account lockout after repeated failures; remove default/weak accounts	Low–Medium	Re-run the dictionary attack and confirm it fails
3	F-03	Place management services on a restricted segment; limit which hosts can reach them	Medium	Confirm the target is unreachable from unauthorized hosts

General hardening: keep all services patched, close unnecessary ports, and monitor for use of insecure plaintext protocols.

7. Conclusion

The target system carried a serious, easily exploitable weakness: unencrypted remote administration that exposed administrative credentials to anyone on the local network. Testing confirmed the risk was real by capturing credentials and gaining access, all within a controlled and authorized environment. The primary remediation — replacing Telnet with SSH — is straightforward and would eliminate the highest-risk finding. Addressing the weak-password and segmentation issues would further strengthen the system's posture. After remediation, a re-test is recommended to confirm the fixes.

Appendix A — Evidence Index

Evidence file	Supports finding	Description
<code>telnet-capture.pcap</code>	F-01	Packet capture of cleartext login
<i>[stream screenshot]</i>	F-01	Wireshark Follow TCP Stream showing credentials
<i>[hydra screenshot]</i>	F-02	Online password recovery
<i>[john output]</i>	F-02	Offline hash cracking
<i>[topology screenshot]</i>	F-03	Network map
<i>[nmap scan files]</i>	F-01–F-04	Enumeration output

Appendix B — Tools Used

Tool	Purpose
Nmap / Zenmap	Enumeration and network mapping
Wireshark / tcpdump	Traffic capture and protocol analysis
Nessus / OpenVAS	Automated vulnerability scanning
Hydra	Online password attack (controlled)
John the Ripper	Offline password cracking (controlled)
telnet / SSH clients	Service access and remediation verification

Appendix C — Glossary (for non-technical readers)

Term	Plain-language meaning
Telnet	An old way to log into a computer remotely; sends everything, including passwords, unprotected
SSH	A modern, secure replacement for Telnet that scrambles (encrypts) all communication
Cleartext / plaintext	Information sent in a readable form that anyone watching the network can see
Credentials	A username and password
Packet capture	Recording network traffic to inspect what was sent
Vulnerability	A weakness that could be used to break into a system
CVSS	A standard 0–10 score for how severe a vulnerability is
Dictionary attack	Guessing a password by trying many common words quickly
Segmentation	Dividing a network so a break-in to one part can't spread to the rest
Proof of concept	A safe demonstration that a weakness is real

This report documents authorized security testing performed in a controlled lab environment. The tools and techniques described are for authorized use only.